

is to assume that using OS-level user administration and leveraging the product's built-in security is enough to protect databases. Unfortunately, this is not true. While the user- and role-based models with strong passwords for SA accounts, etc, are essential, they exist only at the application layer; relying on them alone defeats the purpose of securing databases.

The technical reason behind why legacy methods fail is because a database is a widely and continuously accessible component, which makes it more vulnerable and susceptible to attacks. Database security requirements touch all networking layers, and hence, need careful design. As an example, consider a database server that accepts connections from within the corporate network as well as from outside. It is accessed programmatically by the front-end software, as well as directly by admin and development staff to run queries, etc. It is accessed by backup services, anti-virus servers, and other maintenance-based utilities, and thus is widely accessible. Any of these human or automated means of accessing the database server make it vulnerable to possible attacks originating at various networking touch-points. The latest spyware, and vulnerabilities that revolve around the infamous SQL-injection method, prove that something needs to be done *beyond* these legacy methods. This is exactly where the security mechanisms and solutions that span the lower layers in the networking model come into the picture. Let us look at a few moderately advanced methods to secure database servers, followed by some serious solutions.

Securing database servers

NAT and PAT

Using network address translation and port address translation is the first recommended step. Since database products use pre-defined default ports, it is the first thing hackers look for, and hence should be changed. Even though the database IP address and port is not exposed to the outside world, it is a best practice to change it, to keep spyware and viruses away. Any standard firewall nowadays provides NAT and PAT features.

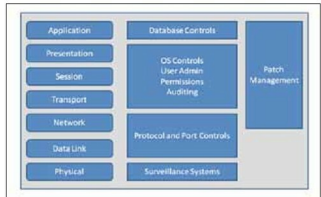


Figure 1: Security methodologies for various layers

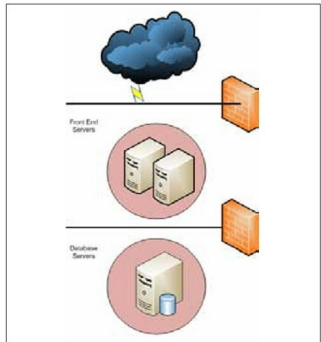


Figure 2: Database server farm

A demilitarised zone (DMZ)

Please refer to Figure 2, which shows a typical database server farm in a corporate IT infrastructure, hosting mission-critical databases and data-warehousing services. As we can see, the database server is not

TechnoMail - Enterprise Email Server
Anti SPAM, Anti Virus, Email Content Filtering

Firewall, Internet Access Control
Content Filtering, Site Blocking

Bandwidth Management System

Managed Email Hosting Solutions

TechnoInfotech®

1, Vikas Permisses, 11 Bank Street, Fort, Mumbai, India - 400 001. Mobile: 09167399917. info@technoinfotech.com